**SERVICIO NACIONAL DE ADUANA DEL ECUADOR**
Dirección Financiera · Departamento de Control Previo

SISTEMA CFPP V2.0

# ESQUEMA DE ROLES Y PERMISOS DE USUARIOS (RBAC)

Matriz de Autorización, Segregación de Funciones y Seguridad de Sesiones

| | | | |
|---|---|---|---|
| **SISTEMA:** | Control Financiero Previo al Pago (SENAE-CFPP) | **VERSIÓN:** | 2.0.0 (Producción) |
| **AMBIENTE OBJETIVO:** | Rocky Linux 9 (x86_64) + PostgreSQL 16 | **FECHA DE EMISIÓN:** | Octubre de 2026 |
| **ELABORADO POR:** | Equipo de Seguridad y Control Interno | **DESTINATARIO:** | Dirección de TICs y Dirección Financiera SENAE |

## 1. PRINCIPIO INSTITUCIONAL DE CONTROL DE ACCESO (RBAC)

El sistema implementa un modelo estricto de **Control de Acceso Basado en Roles (RBAC)**. En cumplimiento de las directrices de control interno de la Contraloría General del Estado (CGE), **se prohíben taxativamente las cuentas genéricas o compartidas**; cada funcionario opera con su credencial personal nominativa y únicamente puede ejecutar acciones permitidas para su perfil y departamento.

## 2. CATÁLOGO OFICIAL DE LOS 10 ROLES INSTITUCIONALES

| ID | ROL INSTITUCIONAL | DEPARTAMENTO / UNIDAD | MISIÓN FUNCIONAL EN EL FLUJO DE CONTROL PREVIO |
|---|---|---|---|
| **R1** | **Directora Financiera** | Dirección Financiera (DFI) | Máxima autoridad del control previo. Emite la Autorización Legal de Pago, autoriza derivaciones especiales y aprueba excepciones. |
| **R2** | **Secretaría DFI** | Dirección Financiera (DFI) | Ventanilla única de ingreso físico. Radica los 8 datos obligatorios de Quipux, folios y realiza la derivación inicial. |
| **R3** | **Jefe de Presupuesto** | DFI - Presupuesto | Reasigna expedientes por turno o cuantía (>= $10k), emite el Visto Bueno Presupuestario obligatorio para continuar a Contabilidad. |
| **R4** | **Analista de Presupuesto** | DFI - Presupuesto | Registra el CUR de Compromiso, ítems presupuestarios, evalúa el Checklist de Presupuesto y activa la pausa por falta de factura. |
| **R5** | **Contador General** | DFI - Contabilidad | Asigna expedientes a analistas contables y emite la Aprobación Contable obligatoria previa a la autorización de pago. |
| **R6** | **Analista Contable** | DFI - Contabilidad | Liquida retenciones, multas, genera el CUR Devengado / Contable y evalúa el Checklist de la fase contable. |

| ID | ROL INSTITUCIONAL | DEPARTAMENTO / UNIDAD | MISIÓN FUNCIONAL EN EL FLUJO DE CONTROL PREVIO |
|---|---|---|---|
| **R7** | **Tesorero / Pagos** | DFI - Tesorería | Registra el lote enviado al Ministerio de Economía y Finanzas (MEF) y el comprobante de transferencia SPI del Banco Central (BCE). |
| **R8** | **Técnico Cobranzas y Garantías** | DFI - Tesorería | Verifica coactivas, garantías aduaneras y retenciones especiales antes del desembolso efectivo. |
| **R9** | **Custodio de Archivo** | Archivo Pasivo DFI | Recibe el expediente físico finiquitado y registra la ubicación topográfica permanente (estante, balda, tomo). |
| **R10** | **Administrador de Sistema (TICs)** | Dirección de TICs | Gestión integral de usuarios, asignación de roles, calendario de feriados nacionales y reglas de campos dinámicos. |

## 3. MATRIZ DE AUTORIZACIÓN Y PERMISOS FUNCIONALES

| OPERACIÓN EN EL SISTEMA | R1 DIR | R2 SEC | R3 J.PRES | R4 A.PRES | R5 CONT | R6 A.CONT | R7 TESO | R8 COBR | R9 ARCH | R10 ADM |
|---|---|---|---|---|---|---|---|---|---|---|
| **Radicación y Creación de Expediente** | SÍ | Sí | NO | NO | NO | NO | NO | NO | NO | SÍ |
| **Edición de Datos Generales (Quipux, Monto)** | SÍ | SÍ | SÍ | SÍ | NO | NO | NO | NO | NO | Sí |
| **Reasignación Interna de Expediente** | SÍ | NO | Sí | NO | Sí | NO | NO | NO | NO | SÍ |
| **Registro CUR Compromiso / Partida** | NO | NO | SÍ | Sí | NO | NO | NO | NO | NO | SÍ |
| **Visto Bueno Jefe de Presupuesto** | SÍ | NO | Sí | NO | NO | NO | NO | NO | NO | SÍ |
| **Pausa / Reanudación de Semáforo SLA** | SÍ | NO | SÍ | Sí | NO | NO | NO | NO | NO | SÍ |
| **Evaluación Checklist de Presupuesto** | SÍ | NO | SÍ | Sí | NO | NO | NO | NO | NO | SÍ |
| **Registro CUR Devengado / Retenciones** | NO | NO | NO | NO | SÍ | Sí | NO | NO | NO | SÍ |
| **Visto Bueno Contador General** | SÍ | NO | NO | NO | Sí | NO | NO | NO | NO | SÍ |
| **Evaluación Checklist de Contabilidad** | SÍ | NO | NO | NO | SÍ | Sí | NO | NO | NO | SÍ |
| **Autorización Legal de Pago Institucional** | Sí | NO | NO | NO | NO | NO | NO | NO | NO | SÍ |
| **Registro SPI-BCE y Lote MEF** | NO | NO | NO | NO | NO | NO | Sí | NO | NO | SÍ |
| **Custodia Pasiva y Ubicación Topográfica** | NO | NO | NO | NO | NO | NO | NO | NO | Sí | SÍ |
| **Gestión de Usuarios y Feriados** | NO | NO | NO | NO | NO | NO | NO | NO | NO | Sí |

## 4. SEGURIDAD DE SESIONES Y PROTECCIÓN DE VULNERABILIDADES

- **Firma Criptográfica HMAC-SHA256:** Cada sesión institucional genera un token criptográfico firmado con la clave maestra `AUTH_SECRET`.
- **Cookies de Sesión Seguras:** El token se almacena en la cookie `senae_session` con atributos `HttpOnly`, `SameSite=Lax` y expiración automática de 7 días.
- **Desafío Captcha Anti-Fuerza Bruta:** El acceso exige resolver un desafío visual SVG generado dinámicamente en memoria, impidiendo ataques automatizados por diccionario o bots.
- **Interceptación en Edge Middleware:** Ninguna pantalla protegida ni endpoint de la API puede ser consultado sin una sesión institucional válida; las peticiones no autorizadas son redirigidas de inmediato al login.